Criptografía y Seguridad en Comunicaciones Web

Resumen

La criptografía moderna constituye la columna vertebral de la seguridad de la información en entornos digitales, proporcionando mecanismos esenciales para garantizar la confidencialidad, la integridad, la autenticidad y el no repudio de los datos. Este documento sintetiza los componentes fundamentales de la infraestructura criptográfica actual a partir de la documentación analizada.

Los hallazgos clave incluyen:

- **Funciones Hash:** Transformaciones unidireccionales que convierten entradas de longitud variable en resúmenes de longitud fija. Son clave para verificar la integridad de datos, almacenar contraseñas de forma segura y validar transacciones en redes *blockchain*.
- **Criptografía Asimétrica (RSA):** Basada en la complejidad matemática de la factorización de números primos grandes. Emplea un par de claves (pública y privada) para cifrar, descifrar y generar firmas digitales en protocolos como HTTPS y VPNs.
- **Criptografía Simétrica (AES):** Estándar de cifrado de alta eficiencia que utiliza la misma clave para cifrar y descifrar bloques de datos de 128 bits. Ofrece la velocidad necesaria para proteger grandes volúmenes de información e intercambios web tras el establecimiento de una conexión.
- **Infraestructura de Llave Pública (PKI) y Autoridades de Certificación (CAs):** Sistema de confianza compuesto por entidades emisoras de certificados digitales (públicas como DigiCert, Let's Encrypt o Amazon Trust Services, y privadas) que vinculan claves públicas con identidades comprobadas para asegurar conexiones SSL/TLS en la Web.

1. Funciones Hash

Una función hash es un proceso algorítmico que transforma datos de entrada de cualquier tamaño en un valor de salida de longitud fija denominado **valor hash** o **resumen hash**. Este resultado suele presentarse como una cadena alfanumérica única.

Propósitos Principales

- **Verificación de Integridad:** Permite comprobar si los datos han sufrido alteraciones. Cualquier cambio en la entrada modifica el hash resultante.
- **Almacenamiento de Contraseñas:** Protege las credenciales de acceso al almacenarlas en formato hash en lugar de texto plano (utilizando técnicas como el *"salting"* para incrementar la seguridad).
- **Identificación Única:** Utilizado para la indexación rápida en bases de datos, sistemas de archivos y en arquitecturas *blockchain*.

Características Fundamentales

1. **Determinista:** Una misma entrada siempre producirá exactamente el mismo valor hash.
2. **Eficiencia de Cálculo:** La función se procesa de manera rápida.
3. **Irreversibilidad:** En funciones hash criptográficas, no es factible reconstruir los datos originales a partir únicamente del resumen hash.
4. **Resistencia a Colisiones:** Es extremadamente difícil encontrar dos entradas diferentes que generen el mismo resultado hash.

Algoritmos Hash

Algoritmo	Estado de Seguridad	Aplicaciones y Contexto
MD5	Inseguro	Rápido, pero vulnerable a ataques de colisión; obsoleto para criptografía moderna.
SHA-1	Obsoleto	Ampliamente utilizado en el pasado, desaconsejado en la actualidad para seguridad.
SHA-256	Seguro	Pertenece a la familia SHA-2. Utilizado en la red Bitcoin, certificados SSL/TLS y aplicaciones seguras.
SHA-3	Seguro	Variante más reciente, diseñada para ofrecer mayor robustez criptográfica.

Ejemplo Práctico de Funcionamiento

- **Entrada:** "Hola mundo"
- **Hash (SHA-256):** a591a6d40bf420404a011733cfb7b190d62c65bf0bcda32b57b277d9ad9f146e
- **Comportamiento:** Si se modifica un solo carácter (por ejemplo, a "Hola Mundo"), el valor hash cambia completamente.

2. Criptografía Asimétrica: Algoritmo RSA

Desarrollado en 1977 por Ron Rivest, Adi Shamir y Leonard Adleman, **RSA** es un algoritmo de clave pública utilizado para cifrado, descifrado y generación de firmas digitales. Soporta sistemas de comunicación segura como HTTPS, redes privadas virtuales (VPNs) y firmas electrónicas.

Principio Matemático y Pares de Claves

RSA fundamenta su seguridad en la dificultad matemática de factorizar números primos de gran tamaño. Utiliza un par de claves matemáticamente vinculadas:

- **Clave Pública:** Se comparte de forma abierta. Se utiliza para cifrar mensajes destinados al propietario de la clave o para verificar sus firmas digitales.
- **Clave Privada:** Se mantiene en secreto absoluto. Se utiliza para descifrar los mensajes cifrados con su correspondiente clave pública o para firmar digitalmente.

Flujo Operativo y Fórmulas Matemáticas

1. Generación de Claves

1. Se eligen dos números primos grandes, p y q.
2. Se calcula el módulo n = p \times q y la función totiente \phi(n) = (p - 1)(q - 1).
3. Se selecciona un exponente público e (frecuentemente 65537).
4. Se calcula el exponente privado d tal que d \times e \pmod{\phi(n)} = 1.

- **Clave Pública:** (e, n)
- **Clave Privada:** (d, n)

2. Cifrado

El mensaje M se convierte en un valor numérico y se cifra mediante la clave pública del receptor: C = M^e \pmod n El texto cifrado C se transmite al destinatario.

3. Descifrado

El receptor utiliza su clave privada para recuperar el mensaje original M: M = C^d \pmod n

4. Firma Digital

- **Emisión de la firma:** El emisor genera un resumen hash del mensaje H(M) (por ejemplo, con SHA-256) y lo procesa con su clave privada: S = H(M)^d \pmod n
- **Verificación de la firma:** El receptor aplica la clave pública del emisor sobre la firma recibida: H(M) = S^e \pmod n Si el valor resultante coincide con el hash del mensaje recibido, la firma se valida como auténtica.

3. Criptografía Simétrica: Estándar AES

El **Estándar de Cifrado Avanzado (AES)** es un algoritmo de cifrado simétrico establecido como estándar por el NIST (*National Institute of Standards and Technology*) en 2001 tras un concurso público. Utiliza una única clave secreta tanto para cifrar como para descifrar la información.

Propósito y Características

- **Confidencialidad:** Protege la información sensible restringiendo el acceso únicamente a quienes poseen la clave secreta.
- **Eficiencia:** Alta velocidad de procesamiento, lo que lo hace idóneo para cifrar grandes volúmenes de datos en comparación con algoritmos asimétricos como RSA.
- **Estructura de Bloques:** Opera en bloques de datos fijados en **128 bits** y admite longitudes de clave de **128, 192 o 256 bits** (AES-128, AES-192, AES-256).

Aplicaciones Comunes

- **SSL/TLS (HTTPS):** Cifrado del tráfico web una vez finalizada la negociación inicial (*handshake*).
- **Cifrado de Discos:** Implementaciones como BitLocker o LUKS.
- **VPNs y Blockchain:** Protección de conexiones seguras y resguardo de claves privadas o datos en billeteras digitales.

Proceso Mecánico

1. **Cifrado:** Toma un bloque de datos (128 bits) y la clave secreta (ej. 256 bits). Aplica rondas iterativas de transformaciones (sustitución, permutación y mezcla) usando la clave expandida para producir un bloque ilegible.
2. **Descifrado:** Aplica las transformaciones en orden inverso utilizando la misma clave para reconstruir el bloque original.

4. Integración de SHA y RSA en Protocolos SSL/HTTPS

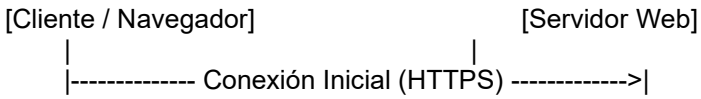
El protocolo **SSL/TLS** (*Secure Sockets Layer / Transport Layer Security*) asegura la navegación web bajo el esquema HTTPS mediante la combinación estratégica de funciones hash (SHA-256) y criptografía asimétrica (RSA).

Certificados Digitales y Autenticación

Un certificado digital emitido por una **Autoridad de Certificación (CA)** asocia la clave pública de un servidor con su identidad.

- **Uso de SHA:** Se calcula el hash SHA-256 de los datos del certificado (dominio, clave pública, emisor, etc.).
- **Uso de RSA:** La CA utiliza su clave privada RSA para firmar dicho hash. Los clientes (navegadores) verifican la firma utilizando la clave pública de la CA para certificar que la información no fue alterada.

Flujo del Handshake TLS



```
    |                                        |
    |<-- Envía Certificado Digital (Dominio, Clave --------|
    |    Pública RSA/ECDSA, Firma CA [SHA-256 + RSA])      |
    |                                        |
[Verificación Client-Side]
1. Calcula hash SHA-256 de los datos.
2. Desencripta firma con Clave Pública CA.
3. Compara resultados.
4. Si coincide -> Conexión Segura Establecida.
```

Caso de Estudio Práctico: Inspección de Certificado SSL/TLS

A partir de los datos técnicos extraídos de la inspección de un certificado emitido para el dominio *.mercadolibre.com.ar:

- **Sujeto (Enviado a):** *.mercadolibre.com.ar
- **Entidad Emisora (Emitido por):** Amazon RSA 2048 M02 (Organización: Amazon)
- **Cadena de Certificación (Jerarquía):**
    1. Amazon Root CA 1 (CA Raíz)
    2. Amazon RSA 2048 M02 (CA Intermedia)
    3. *.mercadolibre.com.ar (Certificado Final)
- **Período de Validez:** Desde el 4 de noviembre de 2024 (21:00:00) hasta el 4 de diciembre de 2025 (20:59:59).
- **Huellas Digitales SHA-256:**
    - **Del Certificado:** 10b4b884f1269767c0c1ccfe7377fbf4a55d830dc75f8629e1575d1a34c810fa
    - **De la Clave Pública:** 24228d9ab7c97d7379eb86fcda2a8d36672b41cb2de44e4c560e82baaef8a4c9

5. Ecosistema de Autoridades de Certificación (CAs)

Una Autoridad de Certificación es una entidad de confianza responsable de emitir, gestionar y revocar certificados digitales.

CAs Públicas

Reconocidas automáticamente por navegadores (Chrome, Firefox, Safari) y sistemas operativos:

1. **Amazon Trust Services (ATS):** Emite certificados SSL/TLS públicos y gratuitos a través de *AWS Certificate Manager (ACM)* para servicios como CloudFront, Elastic Load Balancing y API Gateway.
2. **DigiCert:** Provee certificados SSL/TLS (DV, OV, EV), firma de código y S/MIME, sirviendo a gran parte de las empresas Fortune 500. Integra la histórica **VeriSign** (que representaba aproximadamente el 57.6% del mercado en 2007).
3. **Sectigo (anteriormente Comodo):** Miembro del *CA/Browser Forum*, con un registro histórico de mercado de ~8.3% (2007).
4. **Let's Encrypt:** Entidad sin fines de lucro que automatiza la emisión y renovación gratuita de certificados mediante el protocolo ACME.

5. **GoDaddy:** Popular entre PYMEs, con una cuota histórica de mercado de ~6.4% (2007).
6. **GlobalSign:** Enfocada en seguridad empresarial, firma de código e Internet de las Cosas (IoT).
7. **Entrust:** Provee certificados web, correo y credenciales gubernamentales (como los carnés HSPD-12 del gobierno de EE.UU.), con una cuota histórica de ~1.1% (2007).
8. **Cloudflare:** Entrega certificados integrados a su red de distribución de contenido (CDN).
9. **Google Trust Services:** Emite certificados para la infraestructura interna de Google y Google Cloud Platform.
10. **Microsoft:** Emite certificados para su ecosistema de servicios (Azure, Office 365) confiables por Windows.

CAs Privadas

Diseñadas para entornos corporativos internos, intranets o redes de dispositivos IoT. No son confiables de forma pública por defecto:

- **AWS Private CA:** Servicio para la gestión de recursos internos (servidores, entornos Kubernetes, IoT) compatible con algoritmos como SHA256withRSA y ECDSA.
- **Microsoft Active Directory Certificate Services (AD CS):** Solución integrada para la emisión de certificados dentro de dominios Windows.
- **OpenSSL:** Herramienta de código abierto utilizada para crear y gestionar CAs privadas personalizadas.
- **Entrust Private CA:** Soluciones de infraestructura de clave pública privada a nivel corporativo.
- **IBM Cloud PKI Services:** Gestión de certificados privados en entornos de nube IBM Cloud.

Resumen

RSA

El flujo exacto de Algoritmo RSA entre un emisor (User A) y un receptor (User B) es el siguiente:

1. Para el Cifrado y Descifrado (Confidencialidad):

- El User A cifra el mensaje utilizando la clave pública del receptor (User B).
- Una vez que el mensaje cifrado llega a su destino, el User B utiliza su propia clave privada para descifrarlo y recuperar el texto original.

2. Para la Firma Digital (Autenticación):

- El User A crea un hash del mensaje y lo firma utilizando su propia clave privada.

- Al recibirlo, el User B verifica esa firma utilizando la clave pública del emisor (User A). Si el resultado coincide, la firma es válida y se confirma la identidad del User A.

En el sistema RSA, los usuarios usan claves totalmente diferentes. Cada usuario debe generar su propio par de claves (una pública y una privada) que están vinculadas matemáticamente entre sí, pero que son únicas para esa persona.

Funciona de la siguiente manera:

- Claves Públicas: Son diferentes para cada usuario, pero se comparten de forma abierta con cualquiera. Esto significa que el User A conoce la clave pública del User B, y el User B conoce la clave pública del User A.
- Claves Privadas: Son únicas para cada usuario y se mantienen en secreto absoluto. El User A solo tiene acceso a su propia clave privada, y el User B solo tiene acceso a la suya.

Es por esto que, en el ejemplo de comunicación, se especifica el "dueño" de cada clave:

- Cuando el User A(browser) quiere enviar un mensaje seguro al User B(ML), debe usar específicamente la clave pública del receptor (la del User B) para cifrarlo.
- Cuando el User A(browser) quiere firmar un mensaje para probar su identidad, usa su propia clave privada.
- El User B(ML), al recibir el mensaje cifrado, usará su propia clave privada para descifrarlo.
- Para verificar la firma, el User B(ML) usará la clave pública del emisor (la del User A(browser)).

Sin embargo, es importante hacer una pequeña aclaración sobre cómo se aplica esto en la realidad de la navegación web (HTTPS y TLS):

- Para el cifrado (Navegador enviando a ML): El navegador (cliente) utiliza la clave pública de Mercado Libre (el servidor, extraída de su certificado digital) para cifrar la información inicial de forma segura, y solo Mercado Libre puede descifrarla usando su clave privada.
- Para la firma (Identidad): En la navegación web cotidiana tu navegador no suele generar su propio par de claves RSA ni firma mensajes para identificarse ante el servidor. En la realidad del "Handshake TLS", el proceso de probar la identidad ocurre al revés: es el servidor (Mercado Libre) el que envía su certificado digital y firmas creadas por una Autoridad de Certificación (CA) para demostrarle a tu navegador que es el sitio legítimo.

SSL / TLS y SHA

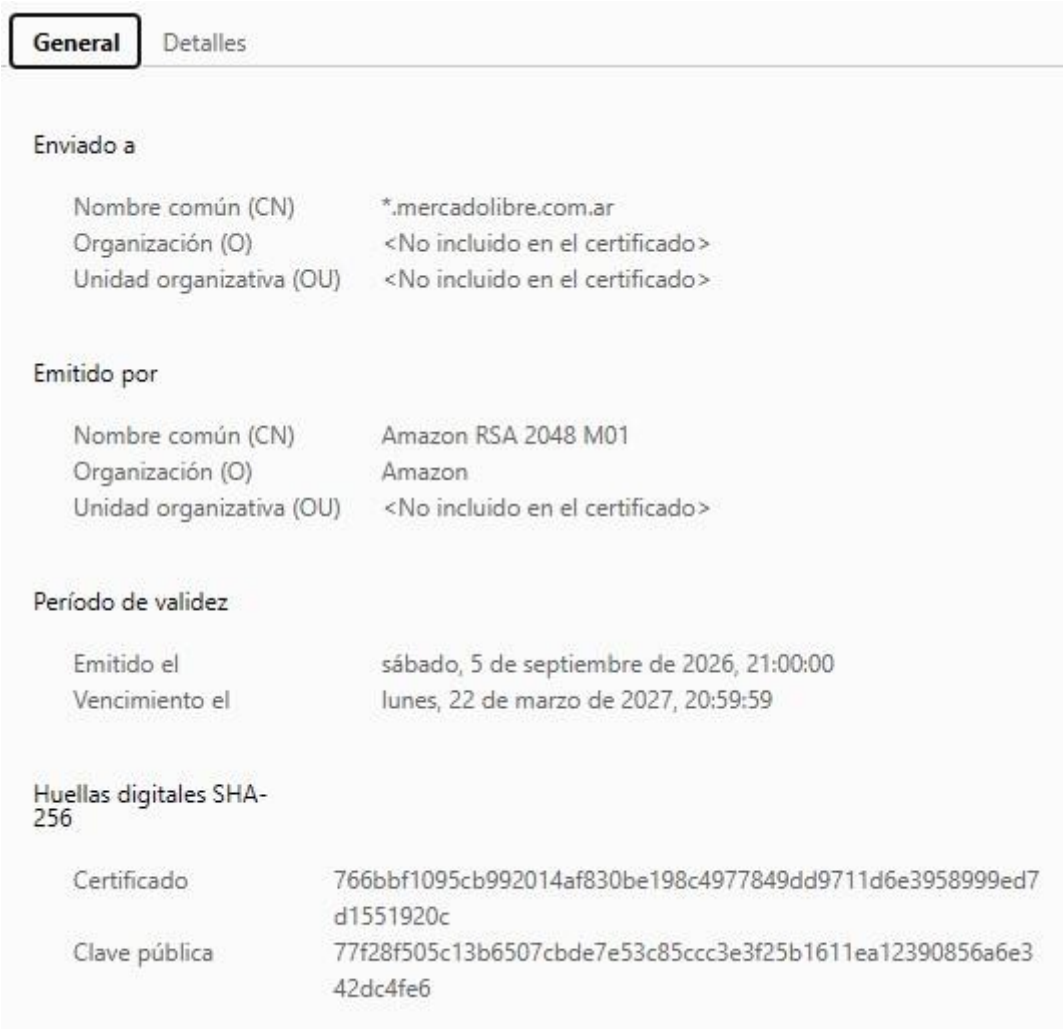
SSL / TLS y **SHA** son componentes fundamentales para la seguridad y la autenticación en las comunicaciones en línea:

- **SSL / TLS (Secure Sockets Layer / Transport Layer Security):** Es el protocolo criptográfico encargado de asegurar las conexiones **HTTPS** en sitios web y proteger el tráfico de datos en la red.
- **SHA (Secure Hash Algorithm):** Es una familia de funciones de **hash criptográfico** (como SHA-1, SHA-256 o SHA-3). Una función hash transforma datos de cualquier tamaño en una cadena o resumen de longitud fija para verificar la **integridad** de los datos, almacenar contraseñas o generar firmas digitales.

¿Cómo se combinan en la práctica?

En los **certificados digitales** utilizados por **SSL/TLS**:

1. **SHA** se utiliza para calcular el resumen (*hash*) de los datos del certificado (como el nombre de dominio y la clave pública).
2. La Autoridad de Certificación (CA) firma ese *hash* (por ejemplo, con el algoritmo RSA) para que los clientes puedan autenticar la validez del sitio web y confirmar que la información no ha sido alterada.



• **Certificado:** Es el hash calculado tomando como entrada la totalidad del certificado digital. Este cálculo procesa todos los datos en conjunto, incluyendo el dominio (*.mercadolibre.com.ar), el emisor, el período de validez y la propia clave pública. Su propósito es funcionar como un identificador único que garantiza que absolutamente ninguna parte del documento ha sido alterada desde que la Autoridad de Certificación lo firmó.

• **Clave pública:** Es el hash calculado de forma exclusiva sobre la clave pública (el valor matemático utilizado para cifrar mensajes o verificar firmas en algoritmos como RSA) que está incrustada dentro del certificado. Como las claves públicas son bloques de datos muy grandes, aplicarles una función hash genera esta cadena alfanumérica manejable que permite a los sistemas identificar y comparar la clave de forma extremadamente rápida.

CÓMO SE COMBINAN SHA Y RSA EN SSL/HTTPS

SSL/TLS (Secure Sockets Layer/Transport Layer Security) es el protocolo que asegura conexiones HTTPS en sitios web. SHA (normalmente SHA-256) y RSA se combinan principalmente en dos contextos dentro de SSL/TLS:

Certificados Digitales (Autenticación):

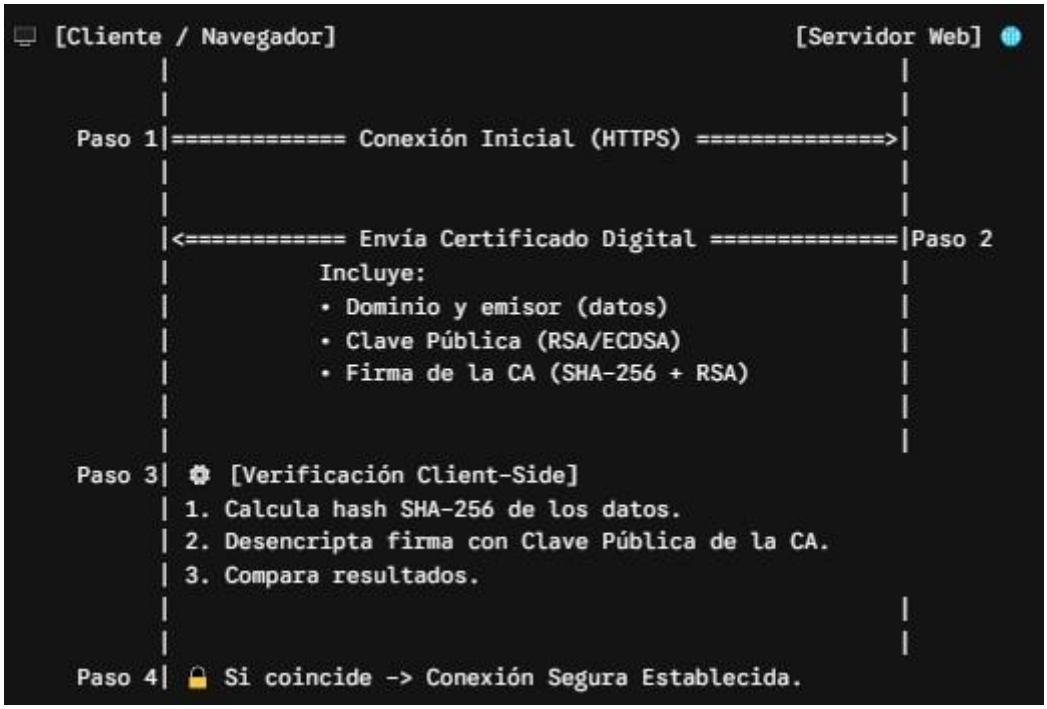
- Un certificado digital (emitido por una Autoridad de Certificación, CA) contiene la clave pública del servidor y está firmado digitalmente.
- **SHA**: Se usa para hashear los datos del certificado (como el nombre del dominio, clave pública, etc.).
- **RSA**: La CA usa su clave privada RSA para firmar el hash, creando una firma digital que los clientes (navegadores) verifican con la clave pública de la CA.
- Esto asegura que el certificado es auténtico y no ha sido alterado.

Flujo en SSL/HTTPS

Handshake TLS:

- El cliente (navegador) se conecta al servidor (por ejemplo, https://example.com).
- El servidor envía su **certificado digital**, que incluye:
  - Clave pública del servidor (RSA o ECDSA).
  - Datos del certificado (dominio, emisor, etc.).
  - Firma digital creada por la CA (hash SHA-256 firmado con RSA de la CA).
- El cliente verifica la firma:
  - Calcula el hash SHA-256 de los datos del certificado.

- Usa la clave pública de la CA para verificar la firma RSA.
- Si coincide, confía en el certificado.



En el Paso 4 de la imagen, lo que debe coincidir para establecer la conexión segura son los dos valores que el cliente obtiene y compara durante el Paso 3:

- El **hash SHA-256** que el cliente (tu navegador) calcula por su propia cuenta basándose en los datos del certificado.
- El resultado de **desencriptar la firma** utilizando la clave pública de la Autoridad de Certificación (CA), lo cual revela el hash original que la CA firmó.

Si ambas cadenas coinciden exactamente, el navegador verifica que la información es auténtica y no ha sido alterada, procediendo a confiar en el certificado.

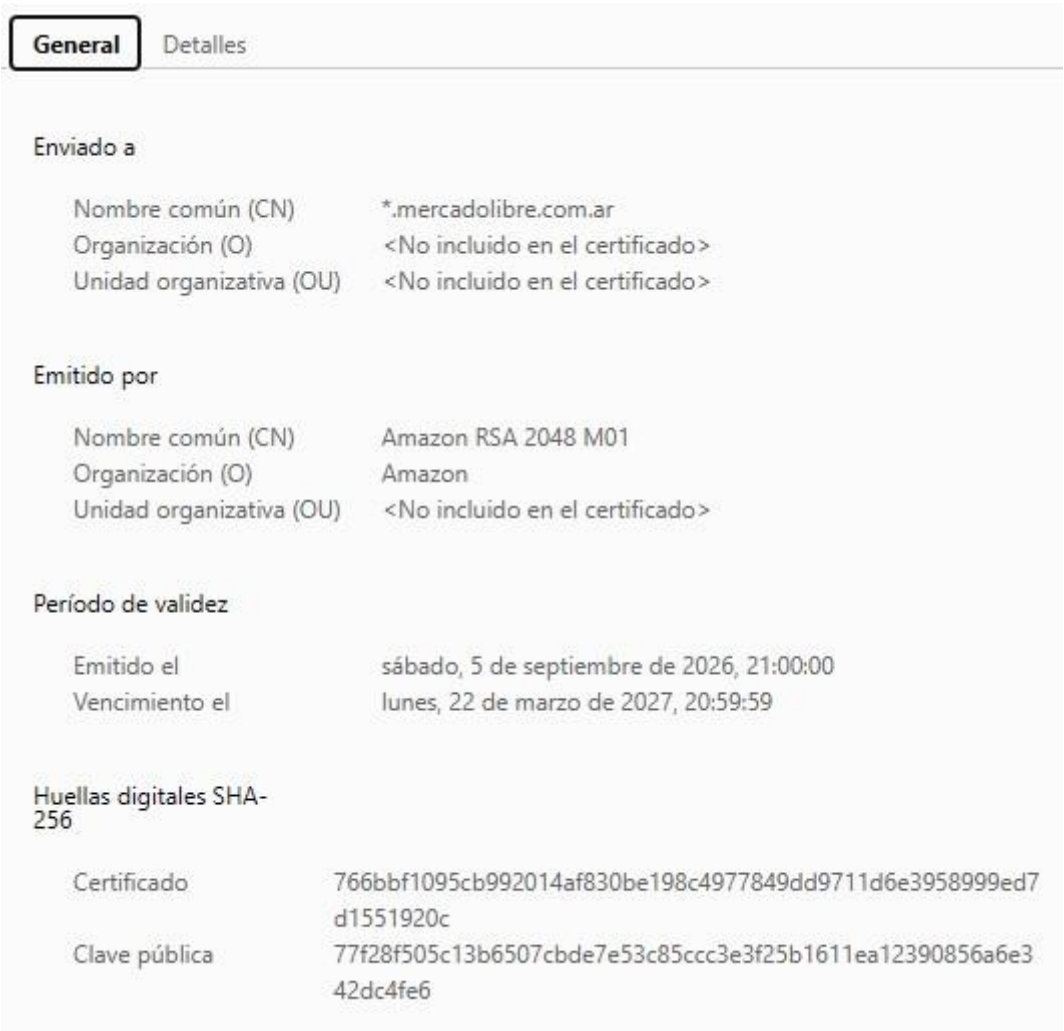
Para calcular el hash SHA-256 durante el proceso de verificación, el navegador (cliente) utiliza los **datos del certificado** que recibe del servidor.

Según tus apuntes, estos datos incluyen elementos como:

- El nombre de dominio.
- La clave pública del servidor.
- El emisor del certificado.

El navegador procesa todo este conjunto de información a través del algoritmo SHA-256 para generar su propio resumen, el cual luego comparará con la firma digital proporcionada por la Autoridad de Certificación (CA) para confirmar que no hubo alteraciones.

INTERPRETACION CERTIFICADO DE SITIO WEB



General | Detalles

Enviado a

Nombre común (CN)	*.mercadolibre.com.ar
Organización (O)	<No incluido en el certificado>
Unidad organizativa (OU)	<No incluido en el certificado>

Emitido por

Nombre común (CN)	Amazon RSA 2048 M01
Organización (O)	Amazon
Unidad organizativa (OU)	<No incluido en el certificado>

Período de validez

Emitido el	sábado, 5 de septiembre de 2026, 21:00:00
Vencimiento el	lunes, 22 de marzo de 2027, 20:59:59

Huellas digitales SHA-256

Certificado	766bbf1095cb992014af830be198c4977849dd9711d6e3958999ed7d1551920c
Clave pública	77f28f505c13b6507cbde7e53c85ccc3e3f25b1611ea12390856a6e342dc4fe6

Datos del certificado (dominio, emisor, etc.):

- **Dominio:** En la sección "Enviado a", el campo **"Nombre común (CN)"** muestra el dominio al que pertenece el certificado, en este caso *.mercadolibre.com. ar. También se ve en la pestaña "Detalles" dentro de la jerarquía.
- **Emisor (CA):** En la sección "Emitido por", el campo **"Nombre común (CN)"** y **"Organización (O)"** muestran quién creó el certificado. Aquí se identifica como Amazon RSA 2048 M02 de la organización Amazon.
- **Validez:** En la sección "Período de validez", se muestran las fechas exactas de "Emitido el" y "Vencimiento el".

 Clave pública del servidor: El valor exacto de la clave pública (la cadena alfanumérica en sí) no se muestra completa en la pestaña "General". Para ver la clave pública completa o su algoritmo (como RSA), tendrías que ir a la pestaña **"Detalles"** y seleccionar el campo específico (generalmente llamado "Clave pública" o "Public Key"). Lo que sí ves en la pestaña "General" bajo "Huellas digitales SHA-256" es el **hash** de esa clave pública, no la clave en sí.

 Firma digital creada por la CA (hash SHA-256):

- En la pestaña "General", en la parte inferior, verás la sección **"Huellas digitales SHA-256"**. El campo **"Certificado"** contiene la larga cadena alfanumérica que representa el hash calculado sobre todos los datos del certificado.
- El campo **"Algoritmo de firma de certificado"** (visible en la lista desplegable de la pestaña "Detalles") indicaría qué sistema se usó (por ejemplo, SHA256withRSA), confirmando que ese hash fue firmado por la CA (Amazon).

AES

La sigla **AES** significa **Advanced Encryption Standard** (Estándar de Cifrado Avanzado). Es un sistema matemático diseñado para proteger información confidencial asegurándose de que solo las personas autorizadas puedan leerla.

Para entenderlo de forma sencilla, AES funciona como un candado que utiliza exactamente la **misma llave** tanto para cerrarse (cifrar) como para abrirse (descifrar). El proceso es el siguiente:

- **Cifrado:** Toma un mensaje (por ejemplo, "Hola mundo") y lo combina con una clave secreta. A través de varias rondas matemáticas donde mezcla, sustituye y reordena la información, transforma ese mensaje en un bloque de texto completamente ilegible.

- **Descifrado:** Cuando la información llega a su destino, el receptor usa esa misma clave secreta para aplicar los pasos exactos a la inversa y recuperar el "Hola mundo" original.

Al ser un proceso extremadamente rápido y eficiente, AES es ideal para proteger enormes volúmenes de datos. Es el candado invisible que protege tu tráfico de internet (HTTPS), tus conexiones VPN y los archivos guardados en discos cifrados.

Por otro lado, la sigla **NIST** corresponde al **National Institute of Standards and Technology** (Instituto Nacional de Estándares y Tecnología). Es la agencia gubernamental que se encarga de definir estándares tecnológicos seguros.

En el año 2001, el NIST organizó un concurso público a nivel mundial para encontrar un nuevo algoritmo de seguridad que fuera robusto y rápido. El sistema ganador de esa competencia fue establecido oficialmente como el estándar AES que se utiliza globalmente en la actualidad.

COMPARATIVA RSA vs. AES

Ambos algoritmos tienen propósitos diferentes y hoy en día **trabajan juntos** para garantizar la seguridad en sistemas modernos como las conexiones web (HTTPS).

La razón por la que coexisten es porque cada uno compensa las debilidades del otro:

- **El rol de RSA (Criptografía Asimétrica):** Al ser un sistema matemático complejo, es computacionalmente pesado y más lento, por lo que no es adecuado para cifrar grandes cantidades de información. Su fortaleza principal es la **autenticación** y el establecimiento seguro de la comunicación. En una conexión HTTPS, RSA se utiliza al principio (durante el llamado "handshake" o apretón de manos) para verificar la firma del certificado digital del servidor y asegurar que es auténtico.
- **El rol de AES (Criptografía Simétrica):** Este algoritmo destaca por su **alta eficiencia y velocidad**, lo que lo hace ideal para cifrar grandes volúmenes de datos de forma rápida. Una vez que RSA ha validado la identidad y establecido una conexión inicial segura, el sistema pasa a utilizar AES para cifrar todo el tráfico web posterior que se intercambia durante esa sesión.